AUDIT REPORT · AUD-20261103-FD7B

paiement-api — microservice de virements SEPA — RTS 2024/1774 · Politique interne PDS-2 (Banque Kerlann, fictive)

Banque Kerlann (fictive) · paiement-api — microservice de virements SEPA

Lead auditor: **Attest CI**

Owner: **DSI — équipe de développement Paiements**

Date: **2026-11-03 23:42**

Run: **20261103-234208-fd7b**

1. Executive summary

OPINION AT TESTING

Unsatisfactory

7 controls tested	**7** findings	**0** findings closed and verified	**7** open findings
0 human approvals	**21** sensitive data items masked in evidence	**4 min 49 s** audit duration	**$0.479 *** measured AI cost



Critical: 1 High: 3 Medium: 3 Low: 0

Key messages

- 7 findings across 7 controls: 1 critical, 3 high, 3 medium.
- 7 findings remain open, with an action plan, an owner and a due date.

2. Scope and method

Engagement	AUD-20261103-FD7B
Entity	Banque Kerlann (fictive)
System	paiement-api — microservice de virements SEPA
System criticality	Supporte des fonctions critiques ou importantes (DORA)
Environment	Pré-production de démonstration
Owner	DSI — équipe de développement Paiements
Lead auditor	Attest CI
Date	2026-11-03 23:42
Framework	RTS 2024/1774 — article 16 : acquisition, développement et maintenance des systèmes TIC · Politique interne PDS-2 (Banque Kerlann, fictive) —

	développement sécurisé
Audited target	paiement-api code repository (SEPA transfer microservice)
Work programme	reviewed by an auditor (Attest CI) · runs/studio/20261103-234208-fd7b/catalogue.json

In scope

- Code source, configuration et chaîne CI du dépôt
- Jeux de données de test versionnés

Out of scope

- Tests dynamiques (DAST) et tests d'intrusion
- Environnements d'exécution et de production
- Historique git

Method

1. Controls are derived from the framework (DORA, RTS 2024/1774, internal policy); severity is the one set by the policy.
2. Each test is a stored Python script, statically checked before execution (read-only) and run with a read-only service account.
3. The verdict comes from the script, never from the model. A screenshot is reviewed by Muse Spark to corroborate; on disagreement the control is flagged for review.
4. SAM 3.1 delineates the proving rows and the personal data, which is masked before distribution.
5. Every fix goes through a change request approved by the system owner, applied with a dedicated account, logged, then verified by the same test (DORA 9(4)(e)).
6. Every event and piece of evidence is sealed in a hash-chained audit trail (SHA-256).

Limitations

- Tests cover the configuration reported by the system, not the actual strength of authentication factors.
- AI-drafted scripts and catalogue must be reviewed by an auditor before being considered validated.
- Fictitious entity and data: demonstration.

3. Findings overview

REF.	RULE	TITLE	SEVERITY	TESTED	AFTER	STATUS	DUE DATE
F-01	PDS-2.1	No hardcoded secrets in versioned code and configuration	Critical	Non-compliant		Open	2026-12-03
F-02	PDS-2.2	TLS server certificate verification never disabled	High	Non-compliant		Open	2027-02-01
F-03	PDS-2.3	Password hashing uses approved functions only	High	Non-compliant		Open	2027-02-01
F-04	PDS-2.6	Test data is synthetic and no production export is versioned	High	Non-compliant		Open	2027-02-01
F-05	PDS-2.4	CI runs static security analysis on each change	Medium	Non-compliant		Open	2027-05-02
F-06	PDS-2.5	Dependencies pinned and audited in CI	Medium	Non-compliant		Open	2027-05-02

F-07	PDS-2.7	Authentication successes and failures are logged	Medium	Non-compliant	Open	2027-05-02

4. Detailed findings and controls

F-01 PDS-2.1 No hardcoded secrets in versioned code and configuration

Critical · Non-compliant · Open

CRITERIA

Verify that no passwords, keys or tokens appear in clear text and that secrets come from a vault or environment variables.

PDS-2.1 · RTS 7(2)

Threshold source: PDS-2.1

> *« Aucun secret (mot de passe, clé, jeton) n'est écrit en clair dans le code source ni dans la configuration versionnée : les secrets viennent d'un coffre ou de variables d'environnement. »*

CONDITION

Observed: `[{"path": "app/config.py", "line": 6, "text": "DB_PASSWORD = \"Az••••\" # TODO : déplacer dans le coffre-fort"}, {"path": "app/config.py", "line": 7, "text": "…`

Expected: `Zero hardcoded secret values; all secrets referenced via os.environ/os.getenv or vault client.`

Found 2 hardcoded secret literal(s) in versioned code.

RISK

Hardcoded secrets allow credential theft from repository access and widen breach impact.

RECOMMENDATION

Remove hardcoded secrets to a vault or environment variables and rotate exposed credentials.

Due date: 2026-12-03 · Owner: DSI — équipe de développement Paiements

Test procedure: GET /api/repo/paiement-api/tree to list files; GET /api/repo/paiement-api/search?q=(password|passwd|secret|api[_-]?key|token)\s*=\s*['"][^'"]+['"] and q=BEGIN.*PRIVATE KEY; for each match GET /api/repo/paiement-api/file?path=<file> to verify whether value is a literal or loaded via os.environ, os.getenv or vault client.



At testing — The screenshot corroborates the test. Screenshot shows hardcoded DB_PASSWORD and JWT_SECRET literals in app/config.py matching the failed test. · 3/3 sensitive data items masked (2 spotted by the AI, the rest by the deterministic safety net)

2026-11-03 23:44:28 · SHA-256 6f480ab099cdc9a1…

F-02 PDS-2.2 TLS server certificate verification never disabled

High · Non-compliant · Open

CRITERIA

Verify that outgoing network calls verify TLS certificates and that verification is never disabled.
PDS-2.2 · DORA 9(3)(a) ; RTS 6(2)(a)
Threshold source: PDS-2.2

> *« Tout appel réseau sortant vérifie le certificat TLS du serveur : la vérification n'est jamais désactivée (`verify=False` interdit). »*

CONDITION

Observed: `["app/payments.py:18:response = requests.post(PSP_URL, json=payload, timeout=TIMEOUT_S, verify=False)"]`
Expected: `Zero matches for verify=False, unverified SSL context or CERT_NONE; requests/http clients use default verification.`
Found 1 active matches disabling TLS certificate verification.

RISK

Disabled TLS verification exposes SEPA transfers to man-in-the-middle interception and data alteration.

RECOMMENDATION

Remove verify=False and unverified contexts and enforce default TLS certificate verification.
Due date: 2027-02-01 · Owner: DSI — équipe de développement Paiements

Test procedure: GET /api/repo/paiement-api/search?q=verify\s*=\s*False and q=ssl\._create_unverified_context and q=CERT_NONE; GET /api/repo/paiement-api/file?path=<file> for each match to confirm context and absence of justification.



At testing — The screenshot corroborates the test. Line 18 in app/payments.py disables TLS certificate verification with verify=False.
`2026-11-03 23:44:14 · SHA-256 03ffbdd593d56b5c…`

F-03 PDS-2.3 Password hashing uses approved functions only

High · Non-compliant · Open

CRITERIA

Verify passwords use argon2, bcrypt, scrypt or PBKDF2 and that MD5 and SHA-1 are not used for security.
PDS-2.3 · RTS 6(3) et 6(4)
Threshold source: PDS-2.3

> *« Les mots de passe sont hachés avec argon2, bcrypt, scrypt ou PBKDF2. MD5 et SHA-1 sont interdits pour tout usage de sécurité. »*

CONDITION

Observed: `{"approved_total": 0, "approved_password_uses": [], "md5_sha1_total": 1, "md5_sha1_security_uses": [{"line": 8, "path": "app/auth.py", "text": "return hashlib.m…`
Expected: `Password hashing uses argon2, bcrypt, scrypt or PBKDF2; no hashlib.md5 or hashlib.sha1 for security purposes.`
Found 1 MD5 or SHA1 security uses with 0 approved password hashing uses.

RISK

Weak hashes allow password recovery after database theft and credential reuse.

RECOMMENDATION

Replace MD5/SHA-1 with argon2, bcrypt, scrypt or PBKDF2 and migrate existing hashes.

Due date: 2027-02-01 · Owner: DSI — équipe de développement Paiements

Test procedure: GET /api/repo/paiement-api/search?q=(argon2|bcrypt|scrypt|PBKDF2|passlib|hashlib\.pbkdf2) and q=(hashlib\.md5|hashlib\.sha1|\bmd5\(|\bsha1\(); GET /api/repo/paiement-api/file?path=<file> for each match to confirm password-hashing use versus non-security use.



At testing — The screenshot corroborates the test. Screenshot shows hash_password in app/auth.py using hashlib.md5 for password verification.

`2026-11-03 23:44:52 · SHA-256 9b670c1eafd915cb…`

F-04 PDS-2.6 Test data is synthetic and no production export is versioned

High · Non-compliant · Open

CRITERIA

Verify test data is declared synthetic and that no production export is stored in the repository.

PDS-2.6 · RTS 16(5)(a)

Threshold source: PDS-2.6

> *« Les données de test sont synthétiques et déclarées comme telles (champ `"synthetic": true`) ; aucun export de production n'est versionné. »*

CONDITION

Observed: `{"production_matches": [{"line": 2, "path": "tests/fixtures/clients_export_prod.json", "text": "\"export\": \"production\","}, {"line": 8, "path": "tests/test_p…`

Expected: `Fixtures contain "synthetic": true; no versioned file contains production exports or real customer data.`

Versioned file tests/fixtures/clients_export_prod.json contains a production export pattern.

RISK

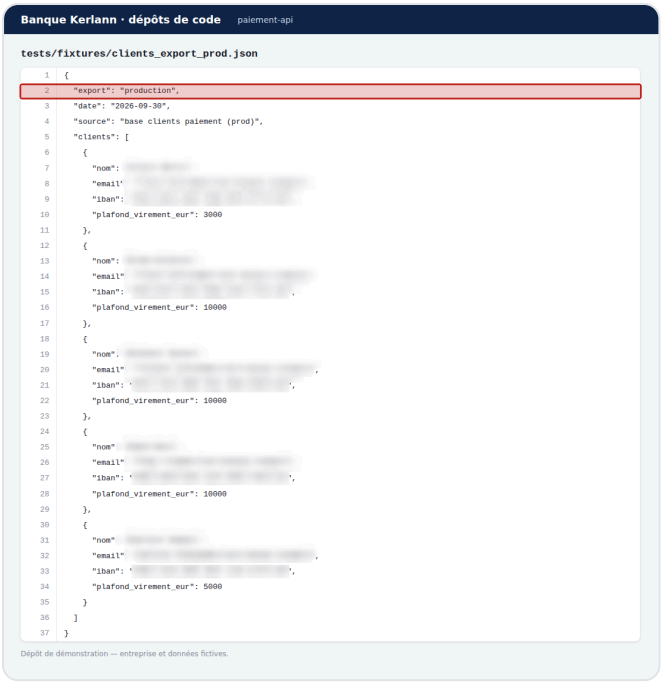
Versioned production data exposes customer data and violates data minimisation in non-production.

RECOMMENDATION

Replace fixtures with synthetic data marked "synthetic": true and remove any production exports from version control.

Due date: 2027-02-01 · Owner: DSI — équipe de développement Paiements

Test procedure: GET /api/repo/paiement-api/tree to list tests and fixtures; GET /api/repo/paiement-api/search?q="synthetic"\s*:\s*true and q=(production|prod_dump|real_iban|export.*prod); GET /api/repo/paiement-api/file?path=<fixture> to verify synthetic true declaration and absence of real production data.



At testing — The screenshot corroborates the test. The file shows export production confirming a versioned production export. · 15/15 sensitive data items masked (11 spotted by the AI, the rest by the deterministic safety net)
`2026-11-03 23:46:08 · SHA-256 f868480cf3c3f5d3…`

F-05 PDS-2.4 CI runs static security analysis on each change

Medium · Non-compliant · Open

CRITERIA

Verify CI executes bandit, semgrep or CodeQL on every modification.
PDS-2.4 · RTS 16(3)
Threshold source: PDS-2.4

> *« La chaîne d'intégration continue exécute une analyse statique de sécurité (bandit, semgrep ou CodeQL) à chaque modification. »*

CONDITION

Observed: `{"workflows": [".github/workflows/ci.yml"], "workflowChecks": [{"path": ".github/workflows/ci.yml", "hasTool": false, "tool": "", "hasOn": true, "hasPush": true…`
Expected: `At least one workflow runs bandit or semgrep or CodeQL on push and pull_request.`
No workflow runs bandit, semgrep or CodeQL on push and pull_request.

RISK

Missing static analysis lets injectable code and hardcoded secrets reach production.

RECOMMENDATION

Add bandit, semgrep or CodeQL to the CI pipeline on every push and pull request.
Due date: 2027-05-02 · Owner: DSI — équipe de développement Paiements

Test procedure: GET /api/repo/paiement-api/tree to list .github/workflows files; GET /api/repo/paiement-api/file?path=<workflow> to verify a step invoking bandit, semgrep or CodeQL with on: [push, pull_request] or equivalent; GET /api/repo/paiement-api/search?q=(bandit|semgrep|codeql) to corroborate.



At testing — The screenshot corroborates the test. The workflow triggers only on push and runs only pip install and pytest with no bandit, semgrep or CodeQL step.
2026-11-03 23:43:44 · SHA-256 bb63a9ca7ffbe74a…

F-06 PDS-2.5 Dependencies pinned and audited in CI

Medium | Non-compliant | Open

CRITERIA

Verify dependencies are pinned to exact versions and audited in continuous integration.
PDS-2.5 · RTS 16(4) et 16(8)
Threshold source: PDS-2.5

> *« Les dépendances sont épinglées à une version exacte (`paquet==version`) et auditées en intégration continue (pip-audit ou équivalent). »*

CONDITION

Observed: `{"requirements_lines": ["flask", "requests>=2.0", "pyjwt==2.8.0"], "total_entries": 3, "pinned_count": 1, "unpinned_entries": ["flask", "requests>=2.0"], "workf…`
Expected: `All requirements use paquet==version with no unbounded specifiers; CI contains pip-audit or equivalent audit step.`
2 of 3 requirements are unpinned and CI audit found is False.

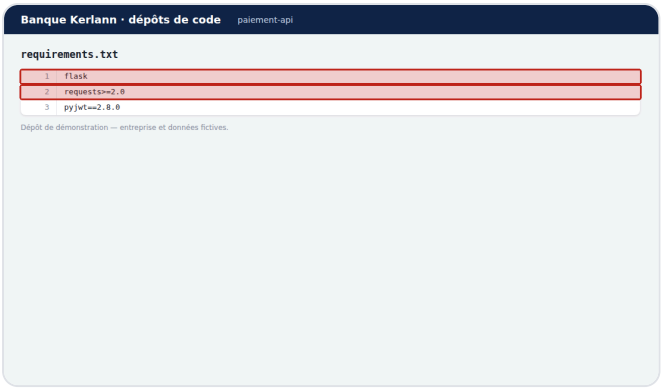
RISK

Unpinned and unaudited dependencies allow introduction of known vulnerable packages.

RECOMMENDATION

Pin all dependencies to exact versions and add pip-audit or equivalent to CI.
Due date: 2027-05-02 · Owner: DSI — équipe de développement Paiements

Test procedure: GET /api/repo/paiement-api/file?path=requirements.txt to verify every entry uses == with exact version; GET /api/repo/paiement-api/tree to list workflows then GET file for each to verify pip-audit or equivalent step; GET /api/repo/paiement-api/search?q=(pip-audit|safety|dependabot) to corroborate.



At testing — The screenshot corroborates the test. The screenshot shows flask with no version and requests>=2.0 without exact pin, matching the reported 2 unpinned entries.
2026-11-03 23:45:23 · SHA-256 94071ff0cc3ec301…

F-07 PDS-2.7 Authentication successes and failures are logged

Medium | Non-compliant | Open

CRITERIA

Verify the application logs both successful and failed authentication events.
PDS-2.7 · RTS 12(2)(c)(i)
Threshold source: PDS-2.7

> *« Les réussites et les échecs d'authentification sont journalisés par l'application. »*

CONDITION

Observed: `{"success_logged": false, "failure_logged": false, "success_file": null, "failure_file": null, "files_checked": [], "matches_count": 0}`
Expected: `Code contains logging for both authentication success and authentication failure events.`
No inspected file logs both authentication success and failure events together.

RISK

Missing auth logs prevent detection of brute-force and credential-stuffing attacks.

RECOMMENDATION

Add logging of authentication successes and failures with appropriate detail without logging secrets.
Due date: 2027-05-02 · Owner: DSI — équipe de développement Paiements

Test procedure: GET /api/repo/paiement-api/search?q=(login|authenticate|auth).*log and q=logger\.(info|warning|error) and q=(authentication.*(success|fail)|login.*(success|fail)); GET /api/repo/paiement-api/file?path=<file> for each match to confirm both success and failure paths are logged.



At testing — The screenshot corroborates the test. The displayed app/config.py contains only static configuration and no authentication success or failure logging statements. · 3/3 sensitive data items masked (1 spotted by the AI, the rest by the deterministic safety net)

2026-11-03 23:46:57 · SHA-256 48a2ce6d268c83d5…

Appendices

A. Traceability matrix

REQUIREMENT	RULE	CONTROL	SCRIPT (SHA-256)	RESULT
RTS 7(2)	PDS-2.1	C1 · No hardcoded secrets in versioned code and configuration	e6d56315f70d74af · written by AI for this engagement	Non-compliant
DORA 9(3)(a) ; RTS 6(2)(a)	PDS-2.2	C2 · TLS server certificate verification never disabled	3f7d446f1f5ca0cc · written by AI for this engagement	Non-compliant
RTS 6(3) et 6(4)	PDS-2.3	C3 · Password hashing uses approved functions only	e4c16e33915dfb01 · written by AI for this engagement	Non-compliant
RTS 16(3)	PDS-2.4	C4 · CI runs static security analysis on each change	b3446758832aa070 · written by AI for this engagement	Non-compliant
RTS 16(4) et 16(8)	PDS-2.5	C5 · Dependencies pinned and audited in CI	3d1a54c689121930 · written by AI for this engagement	Non-compliant
RTS 16(5)(a)	PDS-2.6	C6 · Test data is synthetic and no production export is versioned	05fbfd74878892a8 · written by AI for this engagement	Non-compliant
RTS 12(2)(c)(i)	PDS-2.7	C7 · Authentication successes and failures are logged	5801e40b4414081d · written by AI for this engagement	Non-compliant

B. Evidence register

FILE			SHA-256
evidence/C1_before.png	C1 · At testing	2026-11-03 23:44:28	6f480ab099cdc9a1360c2c4cea12747dae1d19124af608ed4ef557eddb1b811d
evidence/C2_before.png	C2 · At testing	2026-11-03 23:44:14	03ffbdd593d56b5c2617e7935507798b8d74d6a1c2264c4c5f0bd6bf9de88b32
evidence/C3_before.png	C3 · At testing	2026-11-03 23:44:52	9b670c1eafd915cb6df201edf42dc67d9cd479c769ad7b5f49bc574e294bd891
evidence/C4_before.png	C4 · At testing	2026-11-03 23:43:44	bb63a9ca7ffbe74a967dda77e5f0e0f63a2118786a6ad3fc0a6e400cd7a896e7
evidence/C5_before.png	C5 · At testing	2026-11-03 23:45:23	94071ff0cc3ec3013b5c4620d989ef9e69def04847069f8c7a03fba625a6574f
evidence/C6_before.png	C6 · At testing	2026-11-03 23:46:08	f868480cf3c3f5d36560df0f1ff9479a4b9f0e9716709f3c7ac06e670ae51afe
evidence/C7_before.png	C7 · At testing	2026-11-03 23:46:57	48a2ce6d268c83d5db3f0c6a991f9fe5960d6398cabb62f3e5f953a0d29a9c9c

C. AI usage, costs and human oversight

MODEL	CALLS	INPUT TOKENS	OUTPUT TOKENS	IMAGES	COST (USD)

muse-spark-1.3	15	21,048	106,519	0	0.4790
sam-3.1	7	0	0	7	price not published
Total					**0.4790**

Sensitive data (personal data and secrets) in evidence: 14/21 spotted by Muse Spark + SAM, 21/21 masked in the end thanks to the deterministic safety net (page text).

* sam-3.1: price not published (pricing.toml)

Safeguards

- Scripts: allow-listed imports, no write requests (static analysis before execution).
- Read-only test account: any write would be refused by the system (defence in depth).
- Fixes: allow-listed route and parameters, human approval, separate change account.
- Segregation of duties: the approver cannot be the auditor.

D. Integrity

Audit-trail fingerprint when the report was issued. Verify with `python -m attest verify <folder>`.

`c357e5ff28a366dbe86dbd00ef6a7d395905cb30fe993b7f5f49b5e17d02acc9`

F. Framework coverage

20 requirements read: 11 tested automatically (7 controls; 4 regulation clauses covered through the policy), 9 left to document review, 0 to interviews, 0 rejected for lack of an exact quote. Attest only covers the first group.

REF.	TEXT (VERIFIED QUOTE)	TESTABILITY	CONTROL	
RTS 16(1)	« financial entities shall develop, document and implement a policy governing the acquisition, development, and maintenance of ICT systems. »	**document review**	0	Requires review of the policy document itself, which is not visible through the code tree/file/search interface.
RTS 16(1)(a)	« identify security practices and methodologies relating to the acquisition, development, and maintenance of ICT systems; »	**document review**	0	Requires review of policy content, not testable through read-only code and CI files.
RTS 16(1)(c)	« specify measures to mitigate the risk of unintentional alteration or intentional manipulation of the ICT systems during development, maintenance, and deployment. »	**document review**	0	Requires review of policy measures, not observable through code content alone.
RTS 16(2)	« financial entities shall develop, document, and implement an ICT systems' acquisition, development, and maintenance procedure for the testing and approval of all ICT systems prior to their use and after maintenance. »	**document review**	0	Requires review of the testing and approval procedure document, not visible via repository code search.
RTS 16(3)	« the procedure shall contain source code reviews covering both static and dynamic	**tested automatically**	→ PDS-2.4	Static testing part is testable through CI configuration via

	testing, including security testing for internet-exposed systems and applications. »			the read-only interface and is covered by the internal policy control.
RTS 16(3)(a)	« identify and analyse vulnerabilities and anomalies in the source code; »	**document review**	0	Requires review of vulnerability analysis reports, not derivable from code content alone.
RTS 16(3)(b)	« adopt an action plan to address those vulnerabilities and anomalies; »	**document review**	0	Requires review of the remediation action plan document, not visible via code search.
RTS 16(3)(c)	« monitor the implementation of that action plan. »	**document review**	0	Requires review of follow-up and monitoring records, not testable through read-only code files.
RTS 16(4)	« the procedure shall contain security testing of software packages no later than at the integration phase. »	**tested automatically**	→ PDS-2.5	Integration-phase package testing is testable through CI and dependency files and is covered by the internal policy control.
RTS 16(5)(a)	« non-production environments only store anonymised, pseudonymised, or randomised production data; »	**tested automatically**	→ PDS-2.6	Use of synthetic versus production data in versioned fixtures is testable via repository search and is covered by the internal policy control.
RTS 16(5)(b)	« financial entities are to protect the integrity and confidentiality of data in non-production environments. »	**document review**	0	Requires review of access and protection arrangements for non-production data, not provable by code search alone.
RTS 16(7)	« the procedure shall include controls to protect the integrity of source code of ICT systems that are developed in-house or by an ICT third-party service provider. »	**document review**	0	Requires review of code integrity controls like branch protection and signing, not visible through tree/file/search content.
RTS 16(8)	« proprietary software and, where feasible, the source code provided by ICT third-party service providers, as well as source code coming from open-source projects, are to be analysed and tested in accordance with paragraph »	**tested automatically**	→ PDS-2.5	Dependency analysis and testing before deployment is testable through requirements and CI files and is covered by the internal policy control.

PDS-2.1	« Aucun secret (mot de passe, clé, jeton) n'est écrit en clair dans le code source ni dans la configuration versionnée : les secrets viennent d'un coffre ou de variables d'environnement. »	**tested automatically**	1	Testable by searching versioned code and configuration for literal secrets via the read-only search and file interface.
PDS-2.2	« Tout appel réseau sortant vérifie le certificat TLS du serveur : la vérification n'est jamais désactivée (`verify=False` interdit). »	**tested automatically**	1	Testable by searching code for TLS verification disabling patterns via the read-only search interface.
PDS-2.3	« Les mots de passe sont hachés avec argon2, bcrypt, scrypt ou PBKDF2. MD5 et SHA-1 sont interdits pour tout usage de sécurité. »	**tested automatically**	1	Testable by searching code for hashing libraries and forbidden hash functions via the read-only search interface.
PDS-2.4	« La chaîne d'intégration continue exécute une analyse statique de sécurité (bandit, semgrep ou CodeQL) à chaque modification. »	**tested automatically**	1	Testable by inspecting CI workflow files for static analysis steps via tree and file interface.
PDS-2.5	« Les dépendances sont épinglées à une version exacte (`paquet==version`) et auditées en intégration continue (pip-audit ou équivalent). »	**tested automatically**	1	Testable by inspecting requirements files for exact pins and CI files for audit tool via tree, file and search.
PDS-2.6	« Les données de test sont synthétiques et déclarées comme telles (champ `"synthetic": true`) ; aucun export de production n'est versionné. »	**tested automatically**	1	Testable by searching fixtures and tests for synthetic markers and production-export indicators via search and file.
PDS-2.7	« Les réussites et les échecs d'authentification sont journalisés par l'application. »	**tested automatically**	1	Testable by searching application code for authentication logging statements via the read-only search interface.